# Flint front ends — consistency, performance, security, Day-2 operations

Four ways to put one S3 bucket behind agent workloads, compared on four dimensions — six factors each (Performance and Security carry a seventh: the workload envelope, and whether one project can hold a read-only and a read-write session at once), scored 0 (weakest) – 5 (strongest) from the architecture docs and the code, adversarially verified per approach. Pages 2–6 give each chart's reading and the reason behind every number; page 7 maps availability; page 8 places the columns among industry implementations and records the method and maturity behind the scores; page 9 scores lakeFS from its source; page 10 states the multicluster-to-one-bucket contract. NFS-over-S3 is charted in both flavors (sec=sys dashed).

**NFS-over-S3** flint-lite "hub" `shipped + drilled`

One **hub pod** runs an NFS server; client pods mount it over the network with the ordinary kernel NFS client — nothing installed in the pod. The hub keeps the live tree on its own disk (a PVC) and asynchronously publishes whole files to an S3 bucket. Because every client talks to one server, it is the only approach with true shared-filesystem semantics. Its two flavors differ only in how NFS clients are trusted: **sec=sys** (today's deployment — the client self- declares its uid; the network is the only boundary) and **krb5p** (Kerberos — cryptographic per-user identity plus wire encryption; needs a KDC and a keytab on every client node; implemented, interop-verified against MIT krb5 and mounted as of 2026-08-27 — still scored as designed, because no krb5p throughput has been measured).
*Archetype: NFS gateway over object storage (AWS Storage Gateway, Nasuni-class).*

**FUSE** flint-fuse `designed only, deprioritized`

No server. Each pod gets an injected **FUSE filesystem sidecar** that intercepts the app's file I/O, keeps data in the pod, and publishes that pod's workspace subtree straight to the same S3 bucket on a cadence. Each pod holds prefix-scoped bucket credentials, and needs a privileged sidecar (/dev/fuse). Designed in full; currently deprioritized in favor of Lean. *Archetype: bucket-native FUSE (Mountpoint for S3, gcsfuse, s3fs).*

**Lean** flint-lean `built + chaos-drilled · cluster drill open`

No server and no interception: the app works on **plain local files**. An ordinary, unprivileged sidecar (flint-sync) checks the workspace out of S3 at pod start and re-publishes changed files on a cadence, writing to the bucket directly; a small **gateway** carries human-in-the-loop writes and the publish/sync verbs. The agent container holds no bucket credentials. The three file-shaped approaches share one bucket format and are mutually convertible.

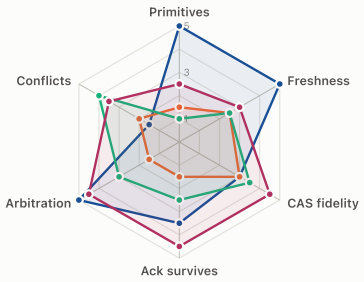
**Forge** flint forge `built · drilled on EC2 · numbers verified`

A **git server per repository** with S3 as its only durable state. Agent pods are stock git clients; a stateless **door** (the lite gateway with a git arm) turns the pod's own ServiceAccount token into a principal and routes to the repository's server pod, where real git (nginx + `http-backend`) serves from a local disk that is a cache and one **syncer** owns every write to the bucket — a push is acknowledged only once its pack and one CAS'd snapshot are in S3. Idles to zero; the bucket is a bare repository, clonable with the server down. The durable unit is a commit: untracked and uncommitted work is not forge's. Numbers checked by four verifiers and eight refuters (none moved); the prose is single-pass.
*Archetype: in-cluster git server over object storage (AWS CodeCommit, closed to new customers 2024).*

## Consistency

NFS-over-S3 (either flavor) · FUSE · Lean · Forge

krb5p ≡ sec=sys here — Kerberos wraps authentication, not coherence



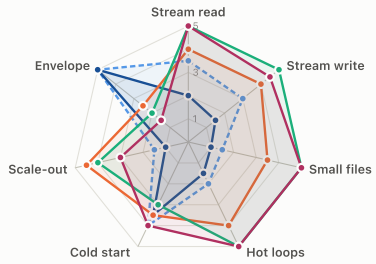

| | NFS | FUSE | Lean | Forge |
|---|---|---|---|---|
| Primitives | 5 | 1.5 | 1 | 2.5 |
| Freshness | 5 | 2.5 | 2.5 | 3 |
| CAS fidelity | 3 | 3 | 3.5 | 4.5 |
| Ack survives | 3.5 | 1.5 | 2.5 | 4.5 |
| Arbitration | 5 | 1.5 | 3 | 4.5 |
| Conflicts | 1.5 | 2 | 4 | 3.5 |

The reading of this chart, and the reason behind every number: page 2.

## Performance

sec=sys · krb5p · FUSE · Lean · Forge

hot paths are local for the direct modes; measured numbers where they exist



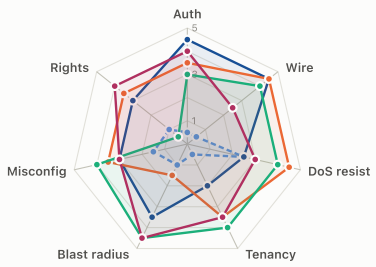

| | sys | krb5p | FUSE | Lean | Forge |
|---|---|---|---|---|---|
| Stream read | 3.5 | 2 | 4 | 5 | 5 |
| Stream write | 3 | 1.5 | 4 | 5 | 4.5 |
| Small files | 1.5 | 1 | 3.5 | 5 | 5 |
| Hot loops | 2 | 1.5 | 4 | 5 | 5 |
| Cold start | 4 | 3.5 | 3.5 | 3 | 4 |
| Scale-out | 1.5 | 1 | 4.5 | 4 | 3 |
| Envelope | 5 | 5 | 2.5 | 2 | 1.5 |

The reading of this chart, and the reason behind every number: page 3.

## Security

sec=sys · krb5p · FUSE · Lean · Forge

scored as designed — krb5p implemented, interop-verified and mounted since 2026-08-27; the floor refuses weaker flavors, per-export WRONGSEC is not built



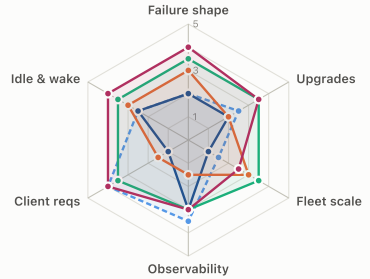

| | sys | krb5p | FUSE | Lean | Forge |
|---|---|---|---|---|---|
| Auth | 0.5 | 4.5 | 3.5 | 3 | 4 |
| Wire | 0.5 | 4.5 | 4.5 | 4 | 2.5 |
| DoS resist | 2.5 | 2.5 | 4.5 | 4 | 3 |
| Tenancy | 0.5 | 2 | 3.5 | 4 | 3.5 |
| Blast radius | 1 | 3.5 | 1.5 | 4.5 | 4.5 |
| Misconfig | 1.5 | 3 | 3.5 | 4 | 3 |
| Rights | 1 | 3 | 3.5 | 0.5 | 4 |

The reading of this chart, and the reason behind every number: page 4.

## Day-2 operations

sec=sys · krb5p · FUSE · Lean · Forge

what it takes to run each front end at fleet scale




| | sys | krb5p | FUSE | Lean | Forge |
|---|---|---|---|---|---|
| Failure shape | 2 | 2 | 3 | 3.5 | 4 |
| Upgrades | 2.5 | 2 | 2 | 3.5 | 3.5 |
| Fleet scale | 1.5 | 1 | 3 | 3.5 | 2.5 |
| Observability | 3.5 | 3 | 1.5 | 3 | 3 |
| Client reqs | 4 | 1 | 1.5 | 3.5 | 4 |
| Idle & wake | 2.5 | 2.5 | 3 | 3.5 | 4 |

The reading of this chart, and the reason behind every number: page 6.

Scores 0 (weakest) – 5 (strongest), as designed, with maturity kept out of the number: one proposer per dimension and one adversarial verifier per column for every column but Forge, whose numbers were scored in a single pass on 2026-09-04 and then checked by one verifier per chart and two refuters per proposed change (four proposed, none survived); its prose remains single-pass. The full method, evidence and maturity record: page 8.

# Why these numbers — Consistency

Consistency is arbitration, not proximity to S3: the hub sweeps primitives, freshness and arbitration because every operation takes the round-trip where ordering is manufactured. The inversion is the story — the hub is nearly weakest at foreign-write surfacing (the “three fates”), while Lean posts the best CAS and conflict scores: its arbitration is designed to turn detection into refusal — designed, not built: the Arbitration cell records the proxy as verified unbuilt, so today that refusal is a control-plane property — chaos-drilled: a deposed writer’s zero citations survived, and the inbox/merge manifest never picks a silent winner on the designed door (a write placed straight into the bucket is undetected until it collides — see the Conflicts cell) — re-drilled since by the boundary-verbs campaign, 42 further kind legs against a real MinIO behind a 65-run formal gate. Both direct modes bottom out in the same mechanism — fsync means emptyDir — but they no longer score alike: FUSE 1.5 against Lean’s 2.5 on the barrier. Forge reads the chart through one primitive, arbitrated at a server: a ref update is a compare-and-swap refused by name, an acknowledged push is in S3 (4.5), and a conflict on its own door is refused and named — while everything filesystem-shaped scores as Lean does or lower, and a write placed straight into the bucket is swept or adopted, not surfaced.

## Consistency

**Strong cross-client primitives** — Whether byte-range locks, O_EXCL create, atomic rename, and shared sqlite/git actually work between clients/pods, not just inside one.

- **NFS 5** — "opens, byte-range locks, O_EXCL and rename are real across every client of the share"; shared sqlite/git is shipped and cluster-proven. krb5p identical — GSS wraps the RPCs, not what they mean. One gap sits behind that quotation: OPEN4_CREATE with GUARDED4 takes the plain create path (dispatcher.rs:1315 → OpenHow::Create; no O_EXCL at ioops.rs:702), so its exclusivity rests on a pre-check across an await — verifier-based EXCLUSIVE4/EXCLUSIVE4_1 create IS enforced (ioops.rs:560–586, flint-lite-consistency.html).
- **FUSE 1.5** — "no cross-pod locks, no shared sqlite / git — refused, not discouraged. ENOLCK and EXDEV"; one survivor: "O_EXCL as a synchronous If-None-Match:* PUT — the one strongly consistent cross-pod primitive" (flint-fuse-consistency.html).
- **Lean 1** — "PLAIN FILES — a real local filesystem, full POSIX, zero interception" — nothing can be made cross-pod, not even FUSE's O_EXCL; cross-pod is "snapshots + sync only"; sqlite/git single-pod only (flint-lean-architecture.html).
- **Forge 2.5** — One primitive, and it is the one forge is made of: a ref update is a compare-and-swap the server judges for every client — old-oid against the local ref AND the last-synced snapshot AND the batch’s own running view (batch.rs step 2; `two_pushes_to_one_ref_in_one_batch_and_exactly_one_wins`), applied as one `update-ref --stdin` transaction — so shared git between pods works by protocol rather than by filesystem. Nothing else on the axis exists: no byte-range locks, no O_EXCL, no rename, no shared sqlite; the working tree is a private clone and cross-pod is “push, then fetch” (design §0, §7).

**Read freshness across clients** — How stale another client's view of your write can be — from enforced close-to-open down to snapshot-until-explicit-sync.

- **NFS 5** — Enforced close-to-open: "the hub is the one coherence authority"; only residuals are a held-open file's open()-time snapshot and readdir cached up to acdirmax 60s (flint-lite-consistency.html).
- **FUSE 2.5** — Another pod reads "a consistent snapshot at most one flush interval + one revalidation old; never read-your-peers'-writes" — bounded automatic staleness, between NFS close-to-open and Lean's explicit sync (flint-fuse-consistency.html).
- **Lean 2.5** — RESCORED 1.5 → 2.5: the design under the old number changed. It read “sync is harness-invoked… never background” and staleness “unbounded until explicit sync” — both now false. The run loop polls sentinels on its own clock; a boundary lands at every floor tick and at every publish touch, so staleness is bounded by the floor (drill B16); and `.flint/remote.seq` tells a reader there is news from a LOCAL file at zero bucket cost (drill B7: a credential-free probe container saw a foreign write land). Still below an enforced close-to-open: the reader is SIGNALLED, not refreshed — it must still pull. Level with FUSE for opposite reasons — FUSE refreshes without the app but cannot bound the window or name a coherent point; lean bounds and names one but needs the agent to act.
- **Forge 3** — Writer = reader by construction — “a fetch never consults S3 and never serves stale refs” (§2) — and a deposed server “stops serving reads as well as writes” rather than answer `upload-pack` from refs it can no longer prove (§5; lease.rs:171–200). Between fetches the agent’s clone is a snapshot with no bound and no signal — nothing like lean’s `remote.seq` tells it there is news — but a stale PUSH is refused by name, `ng stale info: fetch first` (batch.rs:328), which neither direct mode can say. Fresh on demand, never automatically.

**CAS / conditional-write fidelity** — What If-Match / If-None-Match actually bind: which writer populations, detection vs refusal, cooperative vs enforced.

- **NFS 3** — v1.30 If-Match on PUT/DELETE/move — "a competing write answers 412 instead of silently losing your edit" — but detection between API callers, not exclusion against the mount; evict/hydrate flips ETags (fleets guide).
- **FUSE 3** — Verifier raised 2.5 to 3: publishes are 100% CAS-guarded ("If-Match on every publish") and "bucket policy enforces conditional writes (s3:if-none-match)" binds every bucket writer — unlike the hub's mount-exempt CAS (fuse-architecture).
- **Lean 3.5** — "the gateway is the enforcement point these cells always lacked — detection becomes refusal"; must-FAIL arms (stale If-Match MUST 412) and per-request epoch validation (flint-lean-architecture.html). Lowered 4 to 3.5 on a code read (2026-08-27): the two mechanisms this cell credited are not built. The sidecar has no HTTP client at all — warp, a server framework, is its only HTTP dependency — so it never speaks to the gateway; and inject.rs puts credentialsSecretRef on the sidecar container as envFrom, so pods do hold bucket write credentials. The architecture page itself files the zero-credentials phrase under "grade 2 — PLAN OF RECORD, not yet built", and the Arbitration cell one spoke over already says "Verified unbuilt".
- **Forge 4.5** — Refusal, not detection, for every writer population, because there is one door: `receive-pack` performs no old-oid check under `proc-receive` (§4, verified on 2.50.1), so the syncer re-implements it and adds the fast-forward test git no longer runs — `a_push_that_matches_the_local_ref_but_not_the_bucket_is_refused`, `a_non_fast_forward_is_refused_unless_the_policy_allows_it`. Bucket side is ONE `If-Match` snapshot CAS per batch carrying every accepted ref (`a_snapshot_cas_refusal_fences_the_syncer`). Not 5: the guarantee rests on one component — git’s own check is bypassed by design — and it is proven against the memory store, never against MinIO or a cluster (§14 phase 1, “still to do”).

**Acked-write crash durability** — Which failure domain an acked write/fsync survives before the write-back tier lands it in S3.

- **NFS 3.5** — "an acked write is crash-durable on the hub's PVC immediately" — survives hub crash, reschedule, node crash; only PVC loss converts RPO to loss. Not 5: fsync still does not mean S3 (flint-lite-consistency.html).
- **FUSE 1.5** — fsync ack is "durable to the pod's emptyDir... NOT the pod. NOT S3"; "the loss boundary is POD DEATH" — routine on spot; preStop drains ~9–15 GiB inside a 120s notice, a hard crash drains nothing (flint-fuse-consistency.html).
- **Lean 2.5** — RESCORED 1.5 → 2.5: the boundary-verbs campaign falsified all three clauses of the old reason (“RPO per pod; preStop drain best-effort… hard crash drains nothing”). The drain is now bounded-retry and sized against the ~2-minute spot ceiling — drill B11c: SIGTERM with a writer still running drained in 0 s and cited everything staged. A hard crash no longer drains nothing: uncited work is named durably in `orphans.json` IN THE BUCKET and `recover-staged` re-cites it from bucket truth alone — drill B11b: SIGKILL, fresh emptyDir, replacement pod recovered 8 orphans it could not have known about locally. And the verbs add a durability primitive that did not exist: an agent drops `.flint/publish` and the ack means the bytes are IN S3, not in the pod. Not higher, because an ordinary fsync still reaches only the emptyDir — lean’s durable ack is explicit and opt-in, where NFS’s is transparent.
- **Forge 4.5** — “No path acknowledges a push the bucket does not hold” (§4): the pack is uploaded, the snapshot CAS lands, the ref transaction applies, and only THEN is `ok` reported — `an_acknowledged_push_is_in_the_bucket_before_the_ref_moves`, plus `a_refs_for_push_merges_and_the_merge_survives_a_cold_restore` for the server-created loose objects. A crash between the CAS and the report fails the push at the client; the restart restores from the snapshot (§4, §11). Not 5: the unit is a push — a working-tree fsync survives nothing beyond the pod, and uncommitted work has no RPO (git’s contract): `spec.wipSnapshots` is gone from the CRD (crd.rs:255–261); the answer is a script in the agent’s pod.

**Multi-writer arbitration** — Who arbitrates concurrent writers to the same tree and what a second writer experiences — serialized, refused, or merely detected.

- **NFS 5** — Two writers, one file: "serialized — locks and share reservations are real" — the hub round-trip is where opens, locks and renames get ordered; a second writer blocks or is denied, never corrupts (flint-consistency-comparison.html).
- **FUSE 1.5** — Two writers on one file are "out of contract — one writer per subtree, lease-enforced"; the lease is cooperative CAS that "binds only writers that cooperate" — a credentialed non-cooperator is detected, not stopped (comparison doc).
- **Lean 3** — RESCORED 2.5 → 3: the axis asks what a SECOND WRITER EXPERIENCES, and the first scoring answered only the data-plane half. A deposed sidecar used to leave its agent waiting on an ack forever. Drill B18, measured: the zombie settles the owed ack as `refused-fenced` NAMING the winning epoch, flips `capabilities` to state=fenced/verbs=[], refuses a later sync sentinel, and leaves its tree hash unchanged — silence became an attributable refusal. Not higher because the data plane genuinely does merely detect: Enforced at the control plane and now measured: the chaos drill's deposed straggler self-fenced before its CAS and zero citations survived — but it landed 7,591 further data PUTs (uncited orphans); data-plane fencing awaits P5 at the proxy (chaos leg C3). Verified unbuilt 2026-08-26: no proxy component exists and the only per-request epoch check guards the gateway’s CONTROL endpoints, not the data path — so the split stands, control plane REFUSES (drill B18) while the data plane merely DETECTS (drill B12). P5 would make both arms refuse: estimated 3.5–4, not 5, since it excludes the loser rather than serializing concurrent writers.
- **Forge 4.5** — One syncer per repository owns every write, so two writers to one ref are judged in one place: exactly one gets `ok`, the other `ng` with the reason, and the loser keeps its commits in its own clone — nothing is lost, it rebases. Two SERVERS for one repository are fenced by lean’s lease model: the successor rotates the snapshot before serving a byte, the straggler 412s at its next heartbeat or batch and exits (`a_successor_rotates_and_the_straggler_fences_on_its_next_batch`; a lost renew response is adopted, not fenced). Not 5 because a direct push is refused, never serialised — only a `refs/for/<target>` proposal lets the server merge non-conflicting writers (§6) — and the two-server fence has run in the battery, not on a cluster (falsifier 4).

**Foreign-write conflict surfacing** — The fate of an out-of-band/foreign write against a live tree: silently lost, undetected, or preserved-and-surfaced.

- **NFS 1.5** — S3-side writes vs a live hub: "three fates: silently destroyed by local-wins, undetected while resident, or adopted as truth by a hydration 412"; REST-vs-mount race: "the ETag will not save you" (flint-lite-consistency.html).
- **FUSE 2** — "same three fates as hub mode — destroyed, undetected, or adopted" — mitigated only structurally: the read-only project role and prefix-scoped IRSA narrow who can write foreign at all (flint-fuse-consistency.html).
- **Lean 4** — Foreign manifest entries "are PRESERVED and queued into the inbox for the next sync — never dropped, never deleted"; 412s park into a conflict report; oracle: "both versions recoverable... never a silent winner" (flint-lean-plan.md). Scored on the DESIGNED door: a foreign write arrives as object + inbox entry (the gateway PUT), and both arms above are that path. A write placed straight into the bucket, bypassing the gateway, is outside it and is surfaced only when it collides: an untouched path draws no upload, so no 412, no park and no conflict record — the running pod keeps the old bytes while a replacement pod adopts the new ones through the S3-wins arm, which is the same "adopted as truth by a hydration 412" fate this spoke charges NFS for. Bytes still survive either way; what is absent is DETECTION, and closing it needs bucket versioning plus a reconciliation sweep over uncited versions (verified in code 2026-08-27).
- **Forge 3.5** — Two fates, split at the door. On it — `git push` — a conflict is refused and NAMED: a stale push gets “fetch first”, a `refs/for` merge that conflicts moves no ref and reports the paths (`a_conflicting_merge_moves_no_ref_and_names_the_paths`), and both versions survive as commits, one on each side Off it, the bucket is out of contract: a pack placed straight into `objects/pack/` is named by no snapshot and swept past `orphanGraceSecs` (§10), a foreign snapshot fences the server and is adopted on restart (§5), and a foreign write into the export prefix STANDS (drill C3 refuted “overwritten by the next export”, §17): a manifest-less reader serves it, lean now refuses it — the NFS destroyed-or-adopted class, which is why this is not Lean’s 4 with a better door.

# Why these numbers — Performance

The consistency chart inverted: the direct modes win every hot-path axis because the data path is local — Lean's plain files sweep streaming, small-file and hot-loop I/O, while the hub's measured metadata cliff (create 12.5×, delete 222× slower) is its worst cell. The hub's one win is cold start against a live share (pod churn pays only a mount). krb5p trails sec=sys on every hot-path axis — GSS seals every RPC carrying file data — while Envelope is level at 5 by design: GSS wraps the wire, not capacity. The path is implemented and interop-verified as of 2026-08-27, which is what makes this charge legitimate rather than hypothetical — but no krb5p throughput has been measured, so every cell here is still scored as designed. The Envelope spoke is the admission story - the hot-path 5s hold only for workloads that fit: only the hub hosts working sets beyond node-local disk with no dirty-set cap and shared shapes admissible; FUSE reaches past that disk through stubs and lazy hydration but caps its dirty set and refuses shared shapes, and Lean is bounded in both. Forge's working tree is a plain local clone, so it matches Lean on every hot-path axis; its ceiling is the repository's one server pod on clones (egress binds first), and its Envelope is the narrowest on the page (1.5) by decision — code, in commits.

## Performance

**Streaming read** — Large sequential read throughput on warm/resident data, as the workload experiences it.

- **sys 3.5** — Measured 164 MB/s vs 147 MB/s local (1.1×) — "Streaming is fine; metadata is the constraint" — competitive per client but capped by the wire and the hub's single NIC (flint-lite-for-agent-fleets.md).
- **krb5p 2** — Privacy decrypts every READ payload per RPC. No longer a design estimate over a dormant path — the crypto is implemented, vector-pinned and interop-verified, and a sec=krb5p mount serves reads — but the throughput cost has never been measured, so it stays unquantified — below sys's measured 164 MB/s (pnfs-operator-runbook.md).
- **FUSE 4** — As designed: resident reads are "full local POSIX at disk speed", but "v1 ships the classic daemon data path" — every read byte transits the userspace daemon; passthrough/io-uring are opportunistic only (flint-fuse-architecture.html p3).
- **Lean 5** — "PLAIN FILES — a real local filesystem, full POSIX, zero interception" — reads come from the node's own disk and page cache with nothing of flint's in the path (flint-lean-architecture.html).
- **Forge 5** — The workload reads a plain local clone — "nothing is mounted, nothing is privileged, no sidecar is required" (§7) — so, as for Lean, reads come from the node's disk and page cache with nothing of flint's in the path. The server is touched only by clone, fetch and push.

**Streaming write** — Large sequential write throughput on the application's write path (background publish excluded unless it blocks the app).

- **sys 3** — Measured: 512 MiB sequential write 104 MB/s vs 173 MB/s local — 0.6× of local on the app's write path (flint-lite-for-agent-fleets.md "What it performs like").
- **krb5p 1.5** — Every WRITE payload GSS-wrapped per message on the client and the hub's pure-Rust path; unquantified in docs — qualitatively below sys's measured 0.6×-of-local (pnfs-operator-runbook.md).
- **FUSE 4** — Writes land on the emptyDir working set at local speed minus the classic-FUSE copy path; the 8–13 s/GiB publish rate is background and never blocks the app's write (flint-fuse-architecture.html p3–p4).
- **Lean 5** — The app writes plain local files with zero interception; publish is an asynchronous cadence scan, measured 8.0 s/GiB sidecar-side, outside the write path (flint-lean-0b-measurements.md).
- **Forge 4.5** — Writes land in the local working tree at disk speed; durability is an explicit `git push`, outside the write path. Docked half a point for git's object model on the bytes: a large binary is zlib-compressed into a pack on push and rewritten whole by every `repack -a` and every restore, which is why LFS (`<prefix>/lfs/objects/<oid>`, handed to the client presigned) is the multi-modal answer — built (phase 6, `spec.lfs.enabled`, lfs.rs): the batch API lives in the syncer, the bytes go client-to-store and the pod sees a few hundred bytes of JSON; an object already in the bucket is offered no upload (`an_upload_batch_offers_a_url_only_for_what_is_missing`), and nothing sweeps LFS objects, deliberately (§14).

**Small-file / metadata-heavy** — Throughput of create/stat/delete storms and many-small-file trees (npm install, untar, large clones).

- **sys 1.5** — Measured create 12.5× slower (123/s), delete 222× — "each is a synchronous round trip — and that is what dominates the tools agents actually run"; the guide's own advice: move this to emptyDir (flint-lite-for-agent-fleets.md).
- **krb5p 1** — The same synchronous per-op round trips, each additionally GSS-wrapped and unwrapped; implemented and mounted, still unquantified — strictly below sys's measured 12.5×/222× cliff (pnfs-operator-runbook.md).
- **FUSE 3.5** — Own-subtree create/delete are local — no network RTT — but each op pays a FUSE transition plus "one note*() from every mutating op" into state.db; never measured (flint-fuse-architecture.html p3).
- **Lean 5** — Storms hit the local filesystem natively; the measured 100k-file leg puts all cost in the background barrier (65 s first publish, 1.85 s idle tick, 27 MiB manifest at the 283 B/entry that leg measured — compact encoding has since measured 205 B/entry, ≈20 MiB for the same tree), not app-facing op latency (flint-lean-0b-measurements.md).
- **Forge 5** — A many-small-file tree is git's native shape: the working tree is local and the wire carries one pack — a full clone of this repository (89 MB, 25k objects) cost the server 0.13 CPU-s (§8, measured on loopback). Untracked storms — `node_modules`, build output — never reach forge at all, by contract.

**Hot-loop local I/O** — Latency-sensitive synchronous loops — sqlite transactions, git operations, build dirs, agent scratch — where per-op latency, not bandwidth, paces the tool.

- **sys 2** — "npm install, a build tree, or git clone... will be paced by create/delete, not by bandwidth"; sqlite/git are correct through the mount but every lock/fsync/commit is a network round trip (flint-lite-for-agent-fleets.md).
- **krb5p 1.5** — Same RTT pacing plus per-message GSS crypto on each small synchronous RPC; implemented in-tree, overhead still unquantified — scored as the designed posture (pnfs-operator-runbook.md).
- **FUSE 4** — Single-pod sqlite/git run on the local working set at "disk speed"; fsync-heavy loops still pay per-op daemon transitions; cross-pod shared sqlite/git is refused with errno — a scoping choice, not a slowdown (fuse-architecture p3).
- **Lean 5** — Proven with real binaries: "git fsck --strict clean... sqlite integrity_check ok, all rows present" on plain local files across 3 publish barriers — the loop itself is never intercepted (flint-lean-0b-measurements.md e2e leg).
- **Forge 5** — The loop runs on local files, and the git operations agents run — status, diff, commit, rebase — are themselves local; only push and fetch cross the wire, each one batch round trip at the server. Single-pod sqlite in the tree is local exactly as under Lean; shared shapes are out of scope, not slow (§0).

**Cold start / first access** — Time from a new pod starting against a live, warm share to a usable workspace; after-idle and hibernated wake are priced under Day-2 Idle & wake.

- **sys 4** — The working set persists on the hub's PVC, so agent pod churn pays only a mount — the best per-pod story against a live share; evicted files hydrate at a measured 131 s/GiB — single-stream, with hydrateFetchParallel pinned to 1 so eviction stays observable. The default is 6 and has not been measured; the guide explicitly refuses the division (flint-lite-for-agent-fleets.md).
- **krb5p 3.5** — Same PVC-warm hub machinery, plus GSS context establishment in the mount path — "KDC, per-node keytabs, rpc.gssd" — an added first-access dependency — now exercised end to end (KDC, rpc.gssd, mount) but never timed, so still a design estimate (pnfs-operator-runbook.md).
- **FUSE 3.5** — Boot "imports manifest stubs, no bytes moved" — fastest time-to-first-file — but each touched byte pays hydration: 72.5 s/GiB measured pre-fan-out; 1000-pod correlated starts risk 503 storms (flint-fuse-architecture.html p3, p5).
- **Lean 3** — "cold start downloads the whole workspace; fine at GiB scale" — sequential-loop floor 3.3 s/GiB, 49.5 s for 100k files (loopback MinIO, labelled FLOOR by its own rig); every pod start pays the full checkout even against a live share. Bounded fan-out has since landed and its default is now 32, re-measured proxy-shaped — at a 25 ms round trip a 20k-file checkout runs 39.6 s → 21.3 s (−46%). The earlier 1M loopback figure (16 m 24 s → 7 m 05 s) is NOT fan-out evidence: on loopback fan-out is flat across 16/32/64 (7.57/7.59/7.67 s), so that win was MinIO's single disk. Fan-out is a lever only when the path is round-trip-bound, and it stays a constant-factor win — the structural fact is unchanged: no warm PVC, so every pod re-downloads (lean 0b measurements; Tier 1 read-path measurements 2026-08-27).
- **Forge 4** — A pod start against a live server is a clone at LAN speed from a bitmapped pack — 0.13 CPU-s and 42.9 MB for this repository, 2.5 CPU-s and 1.05 GB on a 1 GiB corpus (§8, loopback); `--single-branch` keeps a 1,000-agent-branch advertisement (74 KB, 4× the CPU) out of it. Every pod re-downloads the history — partial clone makes the clone cheap and the first checkout 2.8× dearer (§8) — and a start against a PARKED repository pays the wake priced under Day-2. On EC2, a clone through the door of a PARKED repository completed in 11 s, pod creation included (§13 F7); phase 0 measured the buy option on the same rig (§12).

**Scale-out ceiling** — How aggregate throughput grows as client/pod count grows, and what shared component caps it.

- **sys 1.5** — "Not a parallel filesystem. One hub is one pod and one NIC" — every client's bytes aggregate into one pod's NIC; graduating is the pNFS profile, not migration (flint-lite-for-agent-fleets.md "What this is not").
- **krb5p 1** — The same one-pod one-NIC ceiling, and the hub's CPU must GSS-wrap/unwrap every byte for every client — the aggregate cap arrives at NIC or crypto CPU, whichever saturates first (pnfs-operator-runbook.md).
- **FUSE 4.5** — No hub in the data plane — "the only always-on component is S3 itself"; throughput scales with pods against S3, bounded by the bucket: 503 SlowDown bursts and an N× re-fetch duplication tax (flint-fuse-architecture.html p1, p4).
- **Lean 4** — Verifier lowered 4.5 to 4: grade-1 proxy is the decided posture — "Proxy posture (decided): grade-1 primary" — every publish and checkout byte transits the proxy tier; grade-2 presigned direct-to-S3 is deferred (lean plan §2.2, §8).
- **Forge 3** — Local I/O scales with pods, as for Lean; what has a ceiling is the repository's server — one pod, one NIC, and "egress binds before CPU": 1,000 clones are 130 CPU-s but 43 GB from one NIC (34 s at 10 Gbps); 1.05 TB and 14 min on the 1 GiB corpus (§8). The lever that moves the bytes to S3 — bundle URIs, verified to cut the server's share of a clone from 42.55 MB to 5.8 KB — needs the CLIENT to opt in (`transfer.bundleURI=true`, ≥ 2.40, protocol v2) and is built (phase 5, bundle.rs): the syncer cuts a bundle on a floor, uploads it beside the packs and advertises a presigned URL re-signed at half its TTL (`a_bundle_is_cut_on_a_floor_and_re_signed_on_half_its_ttl`) — and the storm leg ran on EC2: 1,000 clones per arm, 5.7 MiB of server egress with bundles advertised and the client opted in, 40,409 MiB with the opt-in off (§13 F8). Pushes serialise through one syncer whose cost is per batch, not per push, so it gets cheaper per push as load rises (§4).

**Workload envelope** — Which workloads an approach can admit at all - maximum working set, maximum unpublished dirty set, admissible shapes (shared-RWX, multi-pod sqlite/git). The other axes assume the workload fits.

- **sys 5** — Only the hub hosts working sets beyond node-local disk (PVC + tier evict and hydrate); no dirty-set cap - acked writes land on the PVC; the routing table sends shared-RWX, multi-pod sqlite/git and big-artifact writers here (fuse-architecture p5).
- **krb5p 5** — Same PVC + tier data plane, so the same envelope: TiB-scale working sets, no dirty cap, shared trees admissible - GSS wraps the wire, not capacity; the client-side stack cost is priced under Day-2 (pnfs-operator-runbook.md).
- **FUSE 2.5** — Stubs + lazy hydration mount trees too big to materialize - "the escalation for volumes too large or too lazy" - but dirty is capped by the 120s preStop drain (~9-15 GiB) and shared shapes are refused with errno (fuse-architecture p4-p5).
- **Lean 2** — Bounded in BOTH axes: the workspace must fit the emptyDir budget, checkout refuses above the measured file-count cap, dirtySetCapGiB is tied to spot grace, one writer per subtree - "TiB-scale or lazy volumes are FUSE territory" (lean plan §6).
- **Forge 1.5** — The narrowest on the page, by decision: "this one is for code" (§0). Admitted: tracked files, in commits — the working set is a full clone on local disk (partial clone for sparse working sets only). Not admitted: untracked build output, datasets, checkpoints, `.env`; uncommitted work has no RPO; shared-RWX and multi-pod sqlite do not exist; large binaries are hostile to packs unless `spec.lfs.enabled` moves them client-to-store (phase 6, built; unswept by design). Multi-modal agents are a named use case on that path; an LFS leg ran alongside the EC2 falsifiers and went green.

# Why these numbers — Security

The widest spread: sec=sys sits at the bottom on five of seven axes — identity self-asserted, wire cleartext, the boundary is reachability. krb5p buys the strongest auth and wire, and as of 2026-08-27 on a code path that is implemented, interop-verified against MIT krb5 and mounted rather than dormant; the misconfiguration charge it used to carry is largely paid off by a minimum-flavor floor that fails closed, though that floor still defaults to permissive. FUSE scores 3.5 on tenancy (unforgeable IAM principal tags) yet craters on pod compromise: credentials in every pod plus a privileged sidecar. Lean takes both — tenancy 4 and the best blast radius: the AGENT container holds no bucket credentials (the webhook stamps credentialsSecretRef on the sidecar; proxy-mediated pods carry none at all), seconds revocation, unprivileged sidecar. DoS resistance is quota-hardened at HEAD (B5–B8) but stays a pre-auth surface. Forge carries the strongest identity of the direct modes — an audience-bound ServiceAccount token verified by the apiserver (4) — and Lean's blast radius; its wire is its weakest cell (2.5): nothing in-tree terminates TLS, and the token rides in-cluster as a cleartext Basic password. On the seventh axis krb5p first scored at sec=sys's level: the server proved who the caller was and derived no rights from it. Since 2026-10-16 a principal maps to a uid and permissions bind to it (3), though the lite operator sets no map yet. Forge is the one column where a project holds a reader and a writer by principal (4), FUSE by pod (3.5), and Lean not at all (0.5) — its reader is a FUSE mount. Those three enforced answers were put on the wire the same day — a Kerberos mount, two passthrough pods on one mount, and a reader and a writer on one repository — and the foot names the drills.

## Security

**Client authentication strength** — How strongly a writer must prove who it is before the store or server accepts its operations.

- **sys 0.5** — "Port 2049 is AUTH_SYS: the client asserts its own uid and the server takes it"; B9: "AUTH_SYS trusts wire uid 0, no squash, no in-process authz" — identity is self-declared, not proven; root_squash exists since 2026-10-16, off by default (flint-lite-architecture.html).
- **krb5p 4.5** — Strongest mechanism in the tree, and the acceptance gate the verifier deducted for now exists: FLINT_NFS_MIN_SEC sets a minimum flavor, anything below it is refused with AUTH_TOOWEAK, and SECINFO advertises exactly what the floor will accept rather than inviting clients into a flavor the server would then refuse. The earlier deduction — "accepts AUTH_UNIX unconditionally alongside GSS, so wiring cannot gate acceptance" — no longer holds (sec_policy.rs; server_v4.rs).
- **FUSE 3.5** — SigV4/IRSA machine identity, unforgeable at the store: "every pod holds prefix-scoped credentials (IRSA)" and "IAM principal tags enforce it independently" — strong proof, workload-granular not per-user; designed (fuse-architecture).
- **Lean 3** — Verifier lowered 3.5 to 3: the decided v1 auth is a static bearer, not even per-workspace ("Auth v1: bearer only vs + SigV4 — open"); SigV4/TokenReview deferred — a weaker proof of identity than FUSE's per-pod IRSA (lean plan §9.3, §8).
- **Forge 4** — A per-pod projected ServiceAccount token, audience-bound to `forge.chert.us`, presented as the Basic password and verified at the apiserver by `TokenReview` per session (git.rs:211–230); the credential helper re-reads the projected file on every call, so a deleted pod stops authenticating when its token stops renewing. Refusals are cached ≤ 60 s by token hash, transport failures are not (git.rs:284–294). Stronger than Lean's static bearer, and unlike FUSE's IRSA it proves identity to the cluster rather than to the store. Not higher: the principal is the ServiceAccount, which many pods share — `agentPattern` bounds a branch NAME, not its owner (§14 phase 2) — and the human path is the gateway's bearer until Knox.

**Wire protection** — Confidentiality and integrity of data and control traffic in transit.

- **sys 0.5** — Cleartext RPC: the shipped posture gives "no per-user authentication or wire encryption"; RPC-with-TLS (xprtsec=mtls) is only prospective, attractive once client kernels reach 6.5 (pnfs-operator-runbook.md).
- **krb5p 4.5** — Per-message GSS privacy plus integrity on every NFS RPC that carries file data or metadata, mutually authenticated — "the strongest wire posture in the tree". No longer a paper path: the crypto is implemented to RFC 3961/3962/8009 with RFC 4121 per-message tokens and RFC 2203 §5.3 framing, pinned to published test vectors rather than self-round-trip, interop-verified against MIT krb5 fixtures committed in-tree, and exercised by a real mount -o sec=krb5p against a live KDC. One documented exemption: the Linux client runs per-mount state management (EXCHANGE_ID, CREATE_SESSION) over krb5i on the machine credential whatever the mount's flavor, so those establish-time RPCs are signed rather than sealed — every READ, WRITE, create, delete and lock is sealed, which is what the Performance column charges for. krb5i itself has since been mounted end to end, write-then-read-back, with /proc/mounts asserted so a silent downgrade cannot pass (tests/krb5/run-krb5i.sh). The negative legs exist as of 2026-08-28 (tests/krb5/run-gssneg.sh, 27/27): a wrong service key is refused at decryption, an unknown context handle and a replayed wire record are refused with a GSS auth_stat, and a record whose sequence number is moved to an unused value is refused for its checksum. They found four defects, since fixed — a replayable window-reset, an unenforced RPCSEC_GSS_MAXSEQ, a ticket endtime that was parsed and never read, and a sequence check that ran BEFORE the checksum, letting a keyless peer park an established context's replay window. As designed the cell is unchanged; what moved is that the refusals are now measured rather than assumed (nfs/krb; nfs/gss_framing).
- **FUSE 4.5** — All data-plane traffic is S3 over TLS — "plain S3, no flint server anywhere in the read path"; no cleartext NFS hop exists in this design (flint-lean-architecture.html p2, covering direct-mode FUSE and lean alike).
- **Lean 4** — Verifier lowered 4.5 to 4: no lean doc claims TLS anywhere; grade-1 proxy is the decided posture and carries every publish and checkout byte; grade-2 "bytes go pod to S3 DIRECT" is deferred (lean plan §2.2, §8).
- **Forge 2.5** — As designed, HTTPS at the door is a line in the diagram (§2); nothing in-tree terminates it. The door's listener is plain `warp::serve(…).run(listen)` (flint_hub_gateway.rs:312), the server's nginx listens on 8080 with no `ssl` (spdk-csi-driver/docker/forge/nginx.conf), and the pod's audience-bound token rides both hops as a cleartext Basic password — a network observer inside the cluster holds a live credential. Server-to-S3 is TLS through `flint-store`. Below Lean's 4 because here the data plane IS the gateway hop, where Lean's is S3 — and only above sec=sys because a stolen token is bounded by policy where a claimed uid is not.

**Unauthenticated DoS resistance** — How little a merely-reachable, credential-less peer can do to exhaust memory, state, or availability.

- **sys 2.5** — B5–B8 fixed at HEAD (state-table quota, slot cap, idle deadline, READ clamp), but the surface stays a full stateful NFSv4.1 machine on an open port — "no credential needed"; the defense is caps, not auth (nfs-server-hardening-plan.md).
- **krb5p 2.5** — Same binary, same port, same B5–B8 fixes and the same pre-auth TCP/session surface; no doc claims GSS shrinks the floodable surface — scored equal to sys (nfs-server-hardening-plan.md B5–B8).
- **FUSE 4.5** — No flint-operated door to flood: "the only always-on component is S3 itself" — the reachable data plane is S3, which refuses unsigned requests; the only cluster service is a create-time webhook (flint-fuse-architecture.html).
- **Lean 4** — The gateway is stateless ("no PVC, no epoch of its own, no state") and a successful DoS is availability-only — publishes pause, checkouts wedge; no B6-class state minting, though no B5–B8-style battery yet (flint-lean-architecture.html).
- **Forge 3** — A credential-less peer gets a 401 with `WWW-Authenticate` and is "never dialled" (git.rs:440–445; test at git.rs:1063): authentication precedes the repository's wake, so it cannot scale a parked repository up, and a rejected token is cached. The lever it keeps: every NOVEL bad token is one `TokenReview` at the apiserver before the cache can refuse it — an amplifier against the control plane bounded only by the 8,192-entry map. Behind the door there is no quota: nginx runs `client_max_body_size 0` with buffering off and hour-long timeouts, so an authenticated pusher can stream an unbounded pack into the `emptyDir`; a 180 s wake hold ties up a door slot per request. No B5–B8-style battery.

**Tenancy isolation** — Strength and enforceability of the boundary that keeps one tenant/project from reading or writing another's data.

- **sys 0.5** — "no auth on 2049 — the network is the boundary"; "nfsClientCIDRs cannot express a client in another cluster"; B12 prefix-reuse adoption open at HEAD — "B serves A's files, no race required" (nfs-server-hardening-plan.md B12).
- **krb5p 2** — Proven per-user identity, and since 2026-10-16 the server can carry it to the files: a principal maps to a uid, gid and groups (FLINT_NFS_GSS_IDMAP or LDAP), and an unmapped one is the anonymous identity, never unchecked. Held at 2 all the same: the floor and the map do not touch what pins this axis — same per-prefix hubs, the B12 prefix-reuse adoption hole still open at HEAD, the same network-shaped cross-cluster boundary (attached-nodes-only exists for flint's RWX volume servers, not for the hub) (nfs-server-hardening-plan.md B12).
- **FUSE 3.5** — "IAM scope ends at ws-a/" with principal-tag conditions as "a second, unforgeable layer"; the two-principal split keeps bucket-wide levers out of workspace policies — store-side and unforgeable, but designed-only (fuse-architecture).
- **Lean 4** — "Proxy tenancy: project-granular, dedicated bucket or prefix per project (DECIDED)"; claim identity with "foreign-on-reused-prefix must refuse" arms closes the B12 class; within-project residual accepted for v1 (lean plan §9.6, Phase 1).
- **Forge 3.5** — Per repository: its own pod in the tenant's namespace, its own prefix with a claim that refuses a foreign `projectId` (`a_foreign_project_claim_refuses_the_syncer`), arbitration of overlapping prefixes at the operator including export prefixes (`two_repositories_may_not_export_to_one_prefix`), `spec.consumers` at the door and a per-principal branch policy read by two enforcers. The boundary those rest on is `X-Remote-User`, which "anything that can reach the server pod's git port directly can set itself" (§6): the operator renders a NetworkPolicy admitting only the door — but only when `door.namespace` is set, and only where the CNI enforces it; otherwise "reaching the port is the authorization". The HMAC-derived per-repository secret is the named upgrade, not built.

# Why these numbers — Security (continued)

## Security

**Pod-compromise blast radius** — How little an attacker who owns an agent pod gains (credentials, privileges, forgeable identity) and how fast that gain can be revoked - higher = smaller, faster-contained blast.

**sys 1** — Any compromised pod reaching 2049 "can claim any uid" with no root-squash — root on every reachable share, no per-client credential to revoke; saving grace: "the bucket trusts one principal: the hub" (flint-lite-for-agent-fleets.md).

**krb5p 3.5** — A compromised pod yields only that user's short-lived ticket — "KDC, per-node keytabs, rpc.gssd": keytabs live on nodes, and the KDC can disable the principal; bounded to one identity. Now drilled against a real MIT KDC and a real Linux client rather than assumed, but in a throwaway VM realm, never in production (pnfs-operator-runbook.md).

**FUSE 1.5** — Creds narrow cross-tenant reach "while irreducibly widening what a compromised pod can do to its own subtree"; the pod carries a "privileged · Bidirectional · /dev/fuse" sidecar — node reach; IRSA revocation slow (fuse-architecture).

**Lean 4.5** — "pods hold ZERO bucket write credentials" — verified 2026-08-26 to be the AGENT container specifically: the webhook stamps the credential secret onto the SIDECAR only, the agent container carries no env and no envFrom, and shareProcessNamespace is false, so a compromised agent cannot reach it in either deployment mode. Proxy-mediated deployments hold none in the pod at all, and only they get the "kill the token" revocation speed and proxy-enforced prefix scoping; with credentialsSecretRef the scope is whatever IAM policy you attach, the sidecar an ordinary UNPRIVILEGED process — no /dev/fuse, no PSA conflict; "revocation in seconds — kill the token". The chaos drill locates data-plane enforcement at the PROXY: barriers bypass the gateway today (legs C8/C12).

**Forge 4.5** — An owned agent pod yields no bucket credential of any kind — `credentialsSecretRef` lands as `envFrom` on the SYNCER container of the server pod (render.rs:282–442), and the git container facing the network carries none either — and no privilege: no sidecar, no `/dev/fuse`, no webhook. What it gains is the pod's own projected token: push as that ServiceAccount to repositories listing it, bounded by policy to `agentPattern` branches and `refs/for` proposals. Revocation is pod deletion or SA rotation, felt within the ≤ 60 s review cache. Not 5: a shared ServiceAccount means one pod can push over every sibling's `agent/*` branch, and the server pod runs as root in both images (no `USER`, no `securityContext`).

**Misconfiguration resistance** — Whether the security posture fails closed and survives operator error - secure defaults, unforgeable second layers, refusal over silent degradation.

**sys 1.5** — Verifier raised 1 to 1.5: the flagship footgun is fixed at HEAD a8a1f5a — SECINFO now advertises AUTH_SYS first / AUTH_NONE last, order pinned by a unit test, and "a stock mount now negotiates sec=sys" (compound.rs).

**krb5p 3** — A refusal policy now exists and fails closed: FLINT_NFS_MIN_SEC is validated at startup and an unrecognised value refuses to boot rather than resolving to "no floor", so a typo cannot leave an operator believing enforcement is on while sec=sys is served; the advertisement is derived from the accept rule, so the two cannot drift. Not higher, because the floor still defaults to permissive and must be set deliberately, and KDC/keytab/rpc.gssd wiring remains classic sprawl with no CRD field, Helm value or other in-tree tooling to set it (sec_policy.rs, 2026-08-27).

**FUSE 3.5** — "The webhook must not be the security boundary... a webhook bug is caught by a second, unforgeable layer"; failurePolicy: Fail mandated. Docked for the bootstrap 403 footgun and stale-sidecar exposure (flint-fuse-architecture.html).

**Lean 4** — "detection becomes refusal" at the gateway; an unknown workspace is 404 rather than a guessed prefix (a missing or wrong bearer is 401 — gateway.rs:309; the plan's "404, not 401" phrasing described the unknown-id case, not the credential-less one), the chart refuses to render on credential misconfig; must-FAIL arms "refusing barriers while drifted" — fail-closed; Phase 4 operator now built and kind-drilled — CRD, chart and admission webhook; 40 operator tests, legs B26–B38 green (lean plan §10).

**Forge 3** — Fails closed where it counts: an unparseable policy refuses; a MISSING `pre-receive` does not open the repository because the syncer enforces the same document (`a_missing_pre_receive_does_not_open_the_repository`); a snapshot naming a pack the bucket lacks refuses to serve; a newer snapshot layout is refused; a NetworkPolicy naming the wrong door "breaks every clone" — loud. Fails OPEN on two defaults: no `door.namespace` renders no policy, so the `X-Remote-User` boundary is silently absent (values.yaml), and an absent `branches` block is permissive (`an_absent_policy_is_permissive_and_an_unparseable_one_is_not`) — any listed consumer may move `main`. Both are documented; neither refuses.

**Per-session rights on one project** — Whether one project can hold a read-only session and a read-write session at once, and what enforces the difference — a verified principal at the store or server, a pod-authored mount flag, or nothing.

**sys 1** — Only a client-side `ro` mount, which the CSI publish forces even over operator rw options (pnfs_csi.rs:1602). The server backs none of it: 2049 authenticates nobody, so any pod that can mount gets rw and any uid, and `enforcePermissions` evaluates a CLAIMED uid with root honoured (authz.rs module doc) — defence against accident, not against a session that wants to write. The file API gateway's `--read-only` is for every caller (proxy.rs:648), never one.

**krb5p 3** — The server now derives rights from the proven identity: a principal maps to a uid, gid and groups (FLINT_NFS_GSS_IDMAP or LDAP) and POSIX permissions are enforced against it; an unmapped principal is the anonymous identity, never unchecked. On the wire (tests/krb5/run-authz-gss.sh, the same server path): CONFIRMED on 2026-09-05, REFUTED on 2026-10-16, with a map and without one. Not higher: rights come through file modes, not a per-session grant, and the lite operator sets no map yet, so on a hub every Kerberos user is nobody until one is set by hand.

**FUSE 3.5** — Per pod, and enforced where the pod cannot reach: `readOnly` (the CR's or the volume's) becomes `--read-only` on mount-s3 plus a read-only bind mount (node.rs:425, 522, 555), and in broker mode the pod never holds the key. As designed, IRSA makes the right per principal at the store; as built the broker hands every consumer ONE scope — a static key or a single `FLINT_S3B_STS_ROLE_ARN` (broker.rs:57, 89) — and the REST backend, which is told namespace and ServiceAccount (broker.rs:290–297), is the only per-principal hook. Nothing finer than a pod, and the flag is pod-authored. On the wire 2026-09-05 (s3csi/e2e/run-rights.sh, 24/0): two pods on one FlintPassthroughMount differing only in the volume's `readOnly` — the read-only pod's worker runs mount-s3 with `--read-only` and its write is refused (EROFS) while it reads the read-write pod's file, and both workers hold the SAME access key, so the flag is the only separation.

**Lean 0.5** — No mechanism. A workspace is one writer: the CSI publish hardcodes `read_only: false` (node.rs:903), the CRD has no `readOnly`, and the credential is one key per project (branching design §4.5: `static` cannot scope, cooperative only). A second lean pod on the same prefix does not become a reader — it waits to become the writer. A read-only session exists only by composition, a passthrough mount of `files/` with `readOnly`, which is the FUSE column's score, not this one's.

**Forge 4** — Per ServiceAccount, and enforced twice: `consumers` grants read (crd.rs:114–118); the branch policy judges every push per principal in `pre-receive` and again in the syncer (policy.rs:156). A reader is a consumer with every ref protected and only the writer's SA in `pushers`; `refs/for` stays closed with no `mergeInto` (policy.rs:199–213). Deductions: an absent `branches` block is permissive, so every consumer may push until one is written; the principal is an SA many pods share; and the door must be in front — an empty principal keeps protected refs closed and opens the rest. On the wire 2026-09-05, kind + Cilium (forge/e2e/run-rights.sh, 17/0, rerun 17): a reader in `consumers` only is refused `main` and `refs/for/main` while the writer merges and both read; a forged `X-Remote-User` is overridden at the door but believed on a direct hit to the git port, which the rendered NetworkPolicy blocks — deleting it lets the forged push merge into `main`, the vacuity-breaker — and the no-`branches` repo lets any consumer push `main`.

# Why these numbers — Day-2 operations

Concentration costs the hub the most: both NFS flavors inherit share-wide hang-shaped failures (D-state clients, ~6 min force-detach) and a 3000-Service standing ladder — recurring fleet cost is priced inside Fleet scale (FUSE heartbeats ≈ $3.9k/mo at 3000 shares; Lean publish amplification ≈ 2.9 TiB/day for a hot 2 GiB file). krb5p subtracts further on every client-side axis (KDC, keytabs, rpc.gssd). Lean beats FUSE nearly everywhere by shedding privilege and the restart-in-place choreography; the hub keeps observability (rpoClean, /status) — and Lean's new wedge is a PROXY outage: checkouts, restarts, sync and HITL writes all wedge. A gateway outage alone costs only HITL writes — the sidecar publishes straight to the store (legs C8/C12). Forge sits between the two: one pod per LIVE repository behind a headless Service, errors rather than hangs, restore-from-S3 as the restart, a parked repository that costs nothing but its objects — and a door in the path of every verb.

## Day-2 operations

**Failure shape** — How component failures present to running workloads: blast radius, hang vs error vs bounded loss, and the recovery ceremony they demand.

- **sys 2** — Hub NODE crash is the worst shape on any page: "every client hard-hangs in D-state; Recreate + RWO + ~6 min force-detach; F29's manual arm" — sleep SIGKILL cannot touch; benign pod-crash (13s, park and resume) offsets (fuse-arch p4).
- **krb5p 2** — Same hub concentration, so the identical D-state/force-detach class applies unchanged — and it adds KDC/keytab/rpc.gssd as further mount-path dependencies — wiring that is now exercised rather than prospective; scored as designed (pnfs-operator-runbook.md).
- **FUSE 3** — "a dead mount is ENOTCONN — an error, never a D-state hang"; failure distributes into "frequent, per-pod, LOSS-shaped events" — errors beat hangs, but the loss class is permanent and hub mode does not have it (fuse-architecture p4).
- **Lean 3.5** — "far softer than hub-down; reads never depended on it" — "the softest failure shape" on these pages. Chaos leg C8 corrected its shape: with the gateway at zero replicas the sidecar still published AND cited, because it writes the manifest, window and inbox cells straight to the store and links no HTTP client at all — a gateway outage costs only HITL writes. Held to 3.5 for the PROXY outage, which does wedge checkouts, restarts, sync and HITL writes (leg C12; lean plan §7).
- **Forge 4** — Errors, never hangs, and the working tree is never in the blast radius. A syncer crash fails every push in the batch at the client — none acknowledged — and the pod restarts and restores (§11); node loss is a restore on a replacement with no volume to detach, so the hub's D-state / force-detach class does not exist. S3 down: "pushes fail, clones and fetches keep working until the lease TTL, then the server self-fences" (§11) — read-only, then absent, by design. The door is in the path of every verb (N stateless replicas). Not higher: a wake holds a request up to 180 s and git "does not retry a 503" (§5), and none of this has run on a cluster.

**Upgrades & restart recovery** — Cost and risk of rolling new versions and recovering from process/container restarts under live workloads.

- **sys 2.5** — Measured-benign: "restart + epoch re-claim ≈ 13s; clients park and resume — nothing durable at risk (PVC)", MDS roll ~40s; docked for single-replica Recreate and G15's trap: a schema bump makes rollback a crash-loop (hardening plan G15).
- **krb5p 2** — Everything the sys hub carries, plus per-node keytabs and rpc.gssd join every client-node lifecycle event; the stack is implemented and mounted as of 2026-08-27, but no roll of it has ever been exercised; scored as designed (pnfs-operator-runbook.md).
- **FUSE 2** — "upgrade = pod churn: injection is create-time only... a flint-fuse CVE reaches the fleet by pod churn"; restart is fragile — "the reflex... destroys exactly the dirty set" — plus the 80–110s lease tax on unclean death (fuse-arch).
- **Lean 3.5** — Container restart is first-class in the shipped matrix — "never re-materialize: reload the persisted baseline, rescan to rebuild dirt, self-recognize the lease" — battery-tested; unprivileged sidecar lowers upgrade stakes (lean plan §2.1).
- **Forge 3.5** — Restart is restore-from-S3: nothing to recover in place, no dirty set. A roll is `Recreate` per repository — the old pod releases its lease on SIGTERM (server.rs:154–164) and the successor claims at once, so the blip is a restore: seconds on a packed repository. A policy change does not roll the server (`a_policy_change_does_not_roll_the_server`; both enforcers re-read the document — `a_policy_edit_takes_effect_without_a_restart`). Docked: Recreate is a per-repository outage on every roll, and a newer snapshot layout is refused as FINAL by an older syncer (`a_newer_snapshot_layout_is_refused`), so a rollback after a layout bump is a deliberate crash-stop — G15's shape, chosen.

**Fleet-scale standing footprint** — Standing objects, control-plane load, and recurring coordination cost when the share count reaches thousands.

- **sys 1.5** — "hub: 3000 Services (73% of a /20 CIDR) · 3000 PVCs · the ladder"; cold start at 3000 CRs was a deterministic OOMKill (B3); rate-term blockers are fixed but the per-share standing-object ladder is by design (flint-lite-fleet-scale-plan.md).
- **krb5p 1** — Inherits the hub's entire 3000-object ladder and adds a KDC plus keytab distribution to every client node — standing security state sys does not carry, in every consumer cluster (pnfs-operator-runbook.md).
- **FUSE 3** — "mode: direct — NOTHING standing... one webhook, one bucket", but the page prices its own residue: "epoch heartbeats: 3000 cells at 10s defaults ≈ $3.9k/mo" pending lease-only-while-dirty; 1000-pod reclaim LIST risk (fuse-architecture p2).
- **Lean 3.5** — "Idle = S3 only, structurally. Lease cells exist only while a writer runs" — nothing standing per share, one stateless gateway; costs per-activity: a hot 2 GiB file ≈ 2.9 TiB/day at 60s, "bounded by policy, not physics" (lean plan §6).
- **Forge 2.5** — Between the hub and Lean: a live repository is one pod plus a headless Service, a ConfigMap and an optional NetworkPolicy — no ClusterIP (73 % of a GKE-default /20 at 3,000 repositories is the number that decided it) and no PVC — but those objects stand while parked and the reconcile ladder is lite's, 10 rec/s at 3,000 (§2). At 3,000 repositories with 10 % live: 300 pods, 15 vCPU / 19 GiB reserved, 30 lease PUT/s ≈ $389/mo; all awake, 28 nodes (§2's table). N:1 is hedged — the server is multi-repo-capable — behind three recorded triggers, none of which fires below ~1,000 live.

**Fleet observability** — Ability to answer 'is it healthy, is it clean, what is the RPO' per share from an operable fleet-wide surface.

- **sys 3.5** — Best-instrumented of the four: /status "tells importing from wedged" with recovery point, epoch holder and an active-lease COUNT — lease.rs:320 returns leases.len(), not a client list; hibernate is "verify-then-delete, never assume" on rpoClean; docked for the silent wrong-PV-address trap (fleets guide).
- **krb5p 3** — Same /status + CRD surface, but the GSS path has no operational instrumentation — validated by a real MIT KDC mount and by pynfs --security=krb5, neither of which adds instrumentation — so keytab/context/ticket failures arrive as a new uninstrumented diagnosis class (pnfs-operator-runbook.md).
- **FUSE 1.5** — Deletes the fleet's best witness: "FUSE mode has no equivalent witness [to rpoClean], so the bucket... becomes the only global status surface"; per-pod metrics merely owed; loss rate "must be measured there" (fuse-architecture p4).
- **Lean 3** — Phase 3 names deliverables — "per-pod RPO gauge... publish-failure and checkout-wedged alerts, conflict-report surfacing" — and sync emits a machine-readable conflict report; the gauges shipped and are drilled — gauges.json plus a /metrics rendering off the same struct — but the named alert rules are still owed, and there is no client list — nor does the hub have one (lean plan §5).
- **Forge 3** — The hub's `/status` shape, reused for the ladder (`the_status_document_is_the_shape_the_ladder_reads`): phase, holder, lease epoch, refs, packs, snapshot seq, last push, and a `fenced` field that names WHY (status.rs:59–68); the CRD mirrors it with `serverPhase`, repository stats and conditions (crd.rs:317–360). The RPO question is answered structurally — `rpoClean` is always true because acknowledged means durable. Missing: no metrics endpoint or push/clone counters anywhere in the crate, no per-principal audit beyond an nginx access log that is off, and the export's progress visible only as `exported_commit` in the snapshot — no status field says whether the exported tree is current.

**Consumer footprint** — What must be installed, privileged, or configured on client nodes and pods for the data path to keep working day to day.

- **sys 4** — "Nothing from flint installed" — the data path is the node kernel's NFS client; consumers never get bucket credentials. Residue is config traps: without nconnect 2+ the kernel "silently refuses every additional trunk" (lite-architecture).
- **krb5p 1** — "Wiring it up (KDC, per-node keytabs, rpc.gssd, sec=krb5p mount opts)": every client node gains a keytab, a daemon and a realm dependency — the heaviest consumer requirement of the four — and now a real requirement rather than a prospective one (pnfs-operator-runbook.md).
- **FUSE 1.5** — The injected sidecar is "privileged · Bidirectional · /dev/fuse" in every matched pod; "PSA baseline / restricted refuse privileged sidecars" — forcing a node-broker endgame; kernel floor of plain fuse3 (flint-fuse-architecture.html p1/p2).
- **Lean 3.5** — Sidecar is an "ordinary process — UNPRIVILEGED — no /dev/fuse... no PSA conflict", kernel floor "drops to nothing", and no bucket credentials in the AGENT container (the sidecar carries credentialsSecretRef; proxy-mediated pods carry none at all); under sys: native sidecars (K8s 1.29+) and webhook injection are mandatory (lean-architecture).
- **Forge 4** — Stock `git`, any version; nothing privileged, no sidecar, no kernel dependency, no bucket credential. The residue is one small binary in the agent image — `flint-forge-credential`, a passive helper git execs to read the projected token (§6); the door's contract is only "Basic password = that token" — and two lines of pod spec, a projected ServiceAccount token volume with audience `forge.chert.us` and the `credential.helper` line, which no webhook injects. The storm lever asks more of the client: ≥ 2.40 with `transfer.bundleURI=true`, off by default (§8, §15.11).

**Idle lifecycle & wake** — Cost of a parked share and the safety and latency of winding down and waking back up.

- **sys 2.5** — Two-rung ladder gives disk-only then S3-only cost, verified drain (≈41 s to Ready from suspended — flint-lite-operator.md:427; a hibernated wake is 17 s once the epoch cell was released, and ~80 s when it was not — the 1.32 fix and its own anti-vacuity control), but suspendWithSessions "defaults to suspending anyway" and suspending under a live hard mount is "not data loss; an indefinite hang" (fleets guide; flint-lite-operator.md, flint-lite-1.32-validation-results.md).
- **krb5p 2.5** — The ladder and its hazards are unchanged — the GSS layer rides the same :2049 data path and the runbook's Kerberos section states no interaction with park/wake; scored as designed (pnfs-operator-runbook.md).
- **FUSE 3** — "idle = Hibernated, structurally" — "the idle LADDER becomes vacuous, and with it the B6-class inversions"; the price: "every pod start is a Hibernated-class cold start" plus heartbeat economics (fuse-architecture p2).
- **Lean 3.5** — "Idle = S3 only, structurally. Lease cells exist only while a writer runs" — no ladder, no suspend hazard, no keepalive to get wrong; cold start is a full checkout through the proxy whose rate acceptance is still open (lean plan §6).
- **Forge 4** — One rung: idle for `suspendAfterSecs` ⇒ replicas 0 and the `emptyDir` is gone, so a parked repository costs nothing but its objects — idle is "no git traffic" as designed (§5) but no PUSH as built (status.rs:87; a fetch never reaches the syncer, and the door stamps `requested-at` only to wake, git.rs:343), so read-only use is parked one threshold after its wake and pays it again; the ladder suspends only on a polled `/status` and a poll failure holds forever (`an_unreadable_server_is_never_suspended`); an admin suspend outranks a wake. Wake: the door arms `chert.us/requested-at`, waits on the CR not the pod, and holds the request up to 180 s; the restore is one pack at single-stream rate — sub-second on loopback, 4–8 s/GB at EC2 rates — plus ≈60 s of quiet polls if the last death was unclean (§5). No suspend-under-a-live-mount hazard, because nothing is mounted. Falsifier 7 ran on EC2: IdleSuspended at 0 replicas, then a clone through the door in 11 s on a pod the request created (§13).

# Availability — what still works when a component dies

The radar charts price failure as a score; this matrix shows its shape. Verdicts: ● unaffected ● degraded ● impaired ● outage. Both NFS flavors share one column — failure shape is identical; the KDC row exists only for krb5p.

| | NFS-over-S3 (hub — both flavors) | FUSE | Lean | Forge |
|---|---|---|---|---|
| **What the data path depends on** | The hub pod, its PVC, and the network path to :2049 — for every read and every write. | The in-pod FUSE daemon for every I/O; S3 for non-resident reads and all publishes. | Nothing standing — the app reads and writes plain local files; S3 / gateway are needed only at checkout and publish. | The door and the repository's server pod for every clone, fetch and push; S3 on every push (the ack) and at restore. The working tree is plain local files. |
| **Serving process crashes (hub pod / FUSE daemon / sync sidecar)** | ● **Brief stall** — restart + epoch re-claim ≈ 13 s; clients park and resume — nothing durable at risk (PVC). | ● **Visible errors** — ENOTCONN — an error apps can see; restart-in-place recovers the emptyDir dirty set; open fds stay severed, apps reopen. | ● **App unaffected** — plain files — the app never notices; the restarted sidecar reloads its baseline, rescans, self-recognizes its lease; publishes pause one beat. | ● **Pushes in flight fail** — the syncer is the pod's main container: every push in the batch fails at the client, none acknowledged; the pod restarts and restores from the snapshot (sub-second on loopback); clones during it fail fast; the agent's tree is untouched. |
| **Node hosting it dies (or spot-reclaims uncleanly)** | ● **Share-wide hang** — every client hard-hangs in D-state (SIGKILL cannot touch it); Recreate + RWO ≈ 6 min force-detach; F29's manual arm. Acked data is safe on the PVC. | ● **Per-pod loss** — that pod's unflushed set is gone (hot files: unbounded) plus a 60–110 s subtree write-lockout for the successor; every other pod unaffected. | ● **Per-pod loss** — a hard crash drains nothing — loss = RPO exactly; the successor waits out the same lease lockout; every other pod unaffected. | ● **Restore elsewhere** — no volume to detach: a replacement waits out the lease's quiet polls (≈60 s after an unclean death), rotates the snapshot, restores from S3, serves. Nothing acknowledged is lost; unpushed work on the dead node is gone — git's contract. |
| **S3 outage or throttle** | ● **Serving unaffected** — reads and writes continue from the PVC; the RPO grows; one coordinated retry queue drains the backlog. | ● **Degraded + compound risk** — non-resident reads fail; N uncoordinated engines re-fetch N×; outage + spot reclaim compound — that pod's dirty set is gone. | ● **Running pods unaffected** — local files keep serving and publishes pause — but new pods cannot check out until S3 returns. | ● **Read-only, then fenced** — pushes get ng — the syncer refuses to acknowledge what it cannot store; clones and fetches keep working until the lease TTL, then the server self-fences and exits rather than serve refs it cannot prove it holds. |
| **Control plane down (operator / webhook / gateway + proxy)** | ● **Serving unaffected** — running hubs keep serving; wake and reconcile are blocked — a suspended share cannot wake while no operator reconciles. | ● **New pods blocked** — failurePolicy: Fail — every matched pod CREATE blocks while the webhook is down; running pods unaffected (Ignore would be worse: a silent data black hole). | ● **Four wedges — at the proxy** — proxy unreachable: publishes pause AND checkouts/restarts wedge AND sync is unavailable AND HITL writes fail loudly (chaos leg C12). Gateway down alone: barriers continue — the shipped sidecar writes its cells straight to the store (C8); running pods keep serving throughout. | ● **Door down = no git** — the door is in the path of every verb (N stateless replicas). Operator down: live servers keep serving, but a parked repository cannot wake — the door arms the annotation, only the operator scales — and the held request fails after 180 s. |
| **KDC / Kerberos infrastructure down — krb5p flavor only** | ● **New mounts fail** — new GSS contexts and credential renewals fail; established tickets ride out their lifetime; sec=sys is untouched — it carries no GSS context at all. | **n/a** — no NFS wire. | **n/a** — no NFS wire. | **n/a** — no Kerberos. The analogue is the apiserver: a TokenReview outage refuses NEW sessions once the ≤ 60 s cache expires; sessions in flight finish. |
| **Share idle / parked, then accessed** | ● **Wake required** — an NFS mount against a scaled-to-zero hub hangs until something writes the wake annotation — the data path cannot; the file API answers 503 fast; wake ≈ 41 s suspended, and 17 s hibernated once the epoch cell was released — ~80 s when it was not. | ● **Nothing to wake** — idle = Hibernated structurally; the price moves to every pod start being a cold start — hydration on touch. | ● **Nothing to wake** — idle = S3-only structurally; the price is a full checkout at pod start, budgeted by derived probes. | ● **Wake required — held** — replicas 0 after `suspendAfterSecs`; the next request at the door arms the wake and is HELD up to 180 s (git does not retry a 503); restore = one pack at single-stream rate (4–8 s/GB at EC2 rates) plus ≈60 s of lease wait if the last death was unclean. |

The pattern the docs themselves draw: the hub **concentrates** failure into rare, share-wide, hang-shaped outages; the direct modes **distribute** it into frequent, per-pod, loss-shaped events — "durability becomes an operational statistic — interruption handlers, grace periods, dirty-set caps — instead of an architecture property." Lean's refinement over FUSE is taking the app out of the sidecar's blast radius entirely; its residual concentration point is the gateway/proxy pair. Forge concentrates like the hub — one server per repository, in the path of every git verb — but fails like Lean: errors, never hangs, and a restore in place of a recovery.

Sources: fuse-architecture p4 (failure matrix) · lean plan §2.2/§7 (gateway outage) · flint-lite-architecture p4 + fleets guide (idle/suspend) · pnfs-operator-runbook (Kerberos) · flint-forge-design §5, §11 (the syncer, the lease, the wake).

# Beyond flint — the same archetypes in the industry

These pages are grounded in flint, but the columns model archetypes, and most orderings are structural — set by where arbitration, bytes, and credentials live — so they survive across implementations: the hub column reads on any NFS-gateway-over-object product, FUSE on the bucket-native class, Lean on any checkout-and-sync pattern. The measured decimals (the 12.5×/222× metadata cliff, hydrate and checkout rates) and the hardening state are flint's own. Where other implementations genuinely move numbers:

**The FUSE column is the serverless, bucket-native class.** Metadata-server FUSE filesystems (JuiceFS, Alluxio, CephFS-FUSE) are a different animal: a coherence authority returns, so on the Consistency chart they land near the NFS polygon (real locks, close-to-open) while keeping FUSE's privilege posture, per-pod failure shape, and Day-2 costs.

**fsync semantics are a dial, not a constant.** Mountpoint for S3 completes the upload on fsync/close — "Ack survives" rises toward 4 while streaming-write and hot-loop scores fall; flint's emptyDir ack is the write-back end of the same dial, chosen for latency.

**Lean's CAS and conflict scores are the well-engineered end of sync.** A plain aws-s3-sync-style loop does silent last-writer-wins (conflict surfacing ≈ 1, CAS ≈ 0), and most bucket-native FUSE clients send no conditional writes at all. The sec=sys and krb5p rows, by contrast, are textbook industry NFS facts and transfer unchanged.

**lakeFS is the closest whole-system analogue** — the same doctrine of one bucket format, several front ends: its S3 gateway is lean's grade-1 proxy, its presigned direct mode is the grade-2 lean deferred, lakectl local is checkout-and-sync, and lakeFS Mount ("Everest", enterprise; NFS v3 or FUSE, write support since 0.2.0, a CSI driver in preview) adds a mount front end — though its NFS is local snapshot delivery, not a coherence authority. The contrasts that matter: visibility is explicit-commit, not cadence ("other users or mounts will not see your changes until those changes are committed"); write-mode POSIX is narrower than plain files (no rename, links, or locks — rename alone disqualifies git loops in-mount) and same-branch concurrent mounts resolve *source-wins* — a silent winner. Against that, its server-side arbitration — atomic branch commits, first-class merge conflicts, per-user RBAC, clients holding no bucket credentials — is roughly lean's designed endgame already shipped, at the price flint-lean refuses to pay: an operated KV store (Postgres/DynamoDB) standing beside the bucket. Page 9 scores it from source.

## How these numbers were made — method, evidence, maturity

Scores 0 (weakest) – 5 (strongest): a verified read of the architecture docs at repo HEAD (2026-08-25), every cell re-derived against the code on 2026-08-27 — the flint-lite / strict / fuse / lean architecture pages, the three consistency contracts, the NFS hardening plan and the lean plan of record. Method: one proposer agent per dimension, one adversarial verifier per approach column (six score adjustments adopted), one cross-dimension critic (double-counted facts re-homed; cold start re-anchored to a live share). The 2026-08-27 re-derivation put all 119 cells back through the same shape against the code rather than the docs — 44 proposed changes, 36 refuted — and moved no score; what it corrected was prose. Everything is scored as designed, with maturity shown separately.

hub shipped + drilled

krb5p implemented to RFC 3961/3962/8009 + 4121 + 2203, interop-verified against MIT krb5 and mounted (sec=krb5p) with a minimum-flavor floor, krb5i since mounted end to end with /proc/mounts asserted, and the negative legs now exist — a 27-leg drill against a real KDC covering a wrong service key, an unknown context handle, a replayed wire record and a stale checksum, which found four defects and fixed them

FUSE designed only, deprioritized

Lean built through Phase 6 with six kind drill suites green (78 legs: chaos 12, bucket verbs 28, boundary 14, agent-pod 9, chart 8, operator 7 — each counted from the producing script, not from an evidence log); the real-cluster drill is written (3 legs) but has never been run. B1–B8 and B10 hardening fixes landed at HEAD are reflected; B12 prefix-reuse remains open.

Forge scored 2026-09-04 in a SINGLE pass from the design of record (docs/plans/flint-forge-design.md) and the code at HEAD (c359b8be — scored at a37b7105, every citation re-verified after the fleet-lever and LFS commits landed) — then its NUMBERS went through a smaller shape than the other columns' proposer / verifier / critic: one verifier per chart over all 25 cells and two independent refuters per proposed change. Four changes were proposed (Freshness 3→2, Blast radius 4.5→4, Client reqs 4→3.5, Idle & wake 4→3.5) and 8 of 8 refuters rejected them, so no number moved; the pass corrected two prose claims under unchanged numbers (Client reqs' "nothing installed", and Idle & wake's "no git traffic", which is the design and not the push-only clock as built); a third finding, a stale line number in the Wire cell, was the verifier reading a peer's uncommitted working tree — at HEAD the citation holds. The rationale prose is otherwise single-pass, so hold the ARGUMENTS, not the numbers, to that lower standard; built through phase 6 (syncer, door, operator, export, fleet levers — clone bundles and the pruner — and LFS: 109 tests counted from the source — 49 syncer, 7 end-to-end `git push` through the hook, 35 operator, 18 door), then, after the numbers were verified, all eleven falsifiers ran on EC2 on 2026-09-04 and went green, phase 0 measured the buy option (Gitea) on the same rig, and five composition drills against a local MinIO rig found that one-writer-per-prefix is a mechanism within a product and a convention across them, and that an export is never repaired (§17) — the cells cite those runs where they change a claim, and no number was re-scored on them. A later pass on the restore path (827c5f90) fixed a flat 2.05× memory footprint on that path — whole-object reads, ~20.5 GB for the 10 GB envelope at every pod start, now ranged to a flat 38–40 MiB — and recorded, unfixed, that the lease is not renewed during a restore and the heartbeat does not start until it returns, so a challenger holding a non-rotating 60 s takeover token can seize a large repository mid-restore, inside the 40–80 s such a restore takes (flint-forge-design.md §5). No Security number is re-scored on it; it bounds the maturity behind Forge's blast-radius and freshness cells.

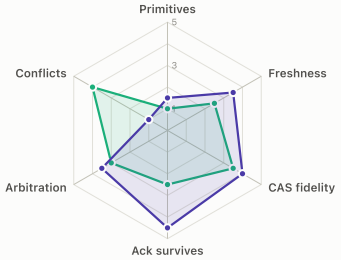
Rights (per-session, one project), Security's seventh axis, was scored 2026-09-05 in a single pass from the code and then put on the wire the same day for three of the five columns: krb5p by tests/krb5/run-authz-gss.sh (14/0; CONFIRMED then, REFUTED on 2026-10-16, when krb5p Rights was rescored 1→3 in a single pass from the code and that rerun, no verifier), FUSE by s3csi/e2e/run-rights.sh (24/0), and Forge by forge/e2e/run-rights.sh on kind + Cilium (17/0, rerun 17). Each is a differential whose sec=sys control MUST deny for the other arm to mean anything, and forge's boundary leg deletes the NetworkPolicy to prove the header is trusted without it. sys is the control arm throughout; Lean's "no" is by construction (one writer, no `readOnly` field) and undrilled.

# lakeFS — scored from source

Scored from source: a shallow clone of github.com/treeverse/lakeFS at 4bb11638 (2026-08-16), read by a 14-agent pass — 5 subsystem recon readers, 4 dimension scorers, 4 adversarial verifiers demanding file:line evidence, 1 comparison critic. Reconciliation: misconfig lowered by a verifier, CAS raised and upgrades trimmed by the critic, failure shape lowered 4→3 in post-publication review. One column, two postures — server API/gateway cells vs lakectl-local cells (each note says which face earns what). Everest mount (NFS/FUSE) is enterprise and absent from this repo.

## Consistency

lakeFS overlaid on Lean — its nearest archetype; full scores in the table

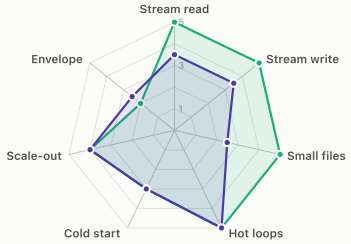



| | NFS | FUSE | Lean | Forge | lakeFS |
|---|---|---|---|---|---|
| Primitives | 5 | 1.5 | 1 | 2.5 | 1.5 |
| Freshness | 5 | 2.5 | 2.5 | 3 | 3.5 |
| CAS fidelity | 3 | 3 | 3.5 | 4.5 | 4 |
| Ack survives | 3.5 | 1.5 | 2.5 | 4.5 | 4.5 |
| Arbitration | 5 | 1.5 | 3 | 4.5 | 3.5 |
| Conflicts | 1.5 | 2 | 4 | 3.5 | 1 |

lakeFS replaced the filesystem with a KV-CAS commit store: acked writes are already in S3 + KV before the app sees success (4.5 vs Lean 2.5, graveler staging), API readers see staged writes immediately, and branch/merge machinery arbitrates with per-key conflict refusal (graveler.go:2289). The filesystem axes invert — no locks, no rename anywhere in the API, no shared sqlite/git — and foreign S3 writes are the mirror of Lean's inbox: hidden, served corrupt under a stale ETag, or GC-deleted (1 vs 4). CAS raised 3.5→4 by the critic: refusal-grade KV insert-if-absent outweighs the missing object-level If-Match.

## Performance

lakeFS overlaid on Lean — its nearest archetype; full scores in the table

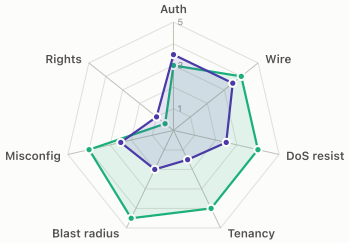



| | sys | krb5p | FUSE | Lean | Forge | lakeFS |
|---|---|---|---|---|---|---|
| Stream read | 3.5 | 2 | 4 | 5 | 5 | 3.5 |
| Stream write | 3 | 1.5 | 4 | 5 | 4.5 | 3.5 |
| Small files | 1.5 | 1 | 3.5 | 5 | 5 | 2.5 |
| Hot loops | 2 | 1.5 | 4 | 5 | 5 | 5 |
| Cold start | 4 | 3.5 | 3.5 | 3 | 4 | 3 |
| Scale-out | 1.5 | 1 | 4.5 | 4 | 3 | 4 |
| Envelope | 5 | 5 | 2.5 | 2 | 1.5 | 2.5 |

An envelope of two postures no single workload gets at once: hot-loop 5 and cold start belong to lakectl-local checkouts (plain files, nothing on the I/O path), while metadata-heavy work pays 2–3 HTTPS round-trips per file (2.5 vs Lean 5). Streaming rides presigned-direct to S3; scale-out is stateless replicas until the KV store binds (4). Envelope 2.5: every POSIX workload needs a full local copy the repo's own CLI warns is non-scalable.

## Security

lakeFS overlaid on Lean — its nearest archetype; full scores in the table

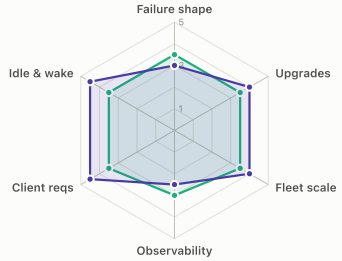



| | sys | krb5p | FUSE | Lean | Forge | lakeFS |
|---|---|---|---|---|---|---|
| Auth | 0.5 | 4.5 | 3.5 | 3 | 4 | 3.5 |
| Wire | 0.5 | 4.5 | 4.5 | 4 | 2.5 | 3.5 |
| DoS resist | 2.5 | 2.5 | 4.5 | 4 | 3 | 2.5 |
| Tenancy | 0.5 | 2 | 3.5 | 4 | 3.5 | 1.5 |
| Blast radius | 1 | 3.5 | 1.5 | 4.5 | 4.5 | 2 |
| Misconfig | 1.5 | 3 | 3.5 | 4 | 3 | 2.5 |
| Rights | 1 | 3 | 3.5 | 0.5 | 4 | 1 |

The score rests on SigV4 per-request signing at the gateway plus presigned URLs keeping bucket credentials server-side — OIDC/SAML/RBAC are enterprise (pkg/auth/build.go Fatals non-basic modes), so shipped OSS is effectively one superAdmin: tenancy 1.5 is where the split bites. Misconfig lowered 3→2.5 by the verifier: blockstore.signing.secret_key defaults to a publicly-known constant in ALL modes (config/defaults.go:107). Default-on hooks put writer-authored webhooks on the server's network position. Rights 1: OSS is one superAdmin; per-user RBAC is enterprise.

## Day-2 operations

lakeFS overlaid on Lean — its nearest archetype; full scores in the table




| | sys | krb5p | FUSE | Lean | Forge | lakeFS |
|---|---|---|---|---|---|---|
| Failure shape | 2 | 2 | 3 | 3.5 | 4 | 3 |
| Upgrades | 2.5 | 2 | 2 | 3.5 | 3.5 | 4 |
| Fleet scale | 1.5 | 1 | 3 | 3.5 | 2.5 | 4 |
| Observability | 3.5 | 3 | 1.5 | 3 | 3 | 2.5 |
| Client reqs | 4 | 1 | 1.5 | 3.5 | 4 | 4.5 |
| Idle & wake | 2.5 | 2.5 | 3 | 3.5 | 4 | 4.5 |

Cheapest fleet citizen per share: a parked repo is KV rows plus bytes (idle 4.5), consumers need only a CLI/SDK (4.5), rolls are stateless restarts. Failure shape lowered 4→3 on review: server/KV death stops the whole data plane for every API/gateway consumer fleet-wide — only lakectl-local working files ride it out — where Lean's running pods keep serving. And the axes don't price the structural contrast: Lean operates ZERO databases (the bucket is the DR story); lakeFS carries an operated KV (refs + all uncommitted staging) plus an external Spark GC job. Observability 2.5: no per-repo metrics dimension; /_health checks neither KV nor blockstore.

**lakeFS beats Lean exactly where the server owns the truth** — an acked write is already in S3 plus the KV store before the app sees success (4.5 vs 2.5), API readers see each other's staged writes immediately (3.5 vs 2.5), and branch/merge machinery genuinely arbitrates concurrent writers with per-key conflict refusal (3.5 vs 3). The structural reason: it replaced the filesystem with a commit store.

**Everything filesystem-shaped inverts.** No locks, no rename, no shared sqlite/git across clients (1.5); metadata storms pay HTTPS round-trips against Lean's local-NVMe 5; every POSIX workload needs a full local checkout. The mount that would fix this — Everest, NFS/FUSE write mode — is enterprise and not in this codebase.

**On out-of-band writes the two systems mirror each other at the door each one offers:** a foreign write through Lean's gateway is preserved and surfaced by the inbox (4); lakeFS offers no such door, and a write into its namespace is hidden, scheduled for GC deletion, or served corrupt under an unverified stored ETag (1). The comparison is narrower than the scores: a write placed straight into Lean's bucket, bypassing its gateway, is undetected too — its own Conflicts cell says so — and the difference there is the bytes' fate, not detection. The object store is lakeFS's private heap, not a shared surface.

**As a fleet citizen lakeFS is cheaper than Lean per share** — parking is free, consumers featherweight, rolls stateless — but it concentrates what Lean distributes: server/KV death stops the whole API data plane fleet-wide (failure shape 3 vs 3.5), OSS multi-tenancy is one superAdmin (tenancy 1.5 vs 4), and the default-on hooks engine puts writer-authored synchronous webhooks inside the commit path (pkg/actions, 6.4k LOC — flagged by the critic from a subsystem no scorer had read).

Method: recon → score → adversarial verify (file:line evidence, 452 tool calls) → cross-dimension critique; reconciliation adopted the verifier's misconfig adjustment and the critic's CAS raise, upgrades trim, and two-postures caveat. Evidence basis differs from the flint pages: the flint columns are doc-grounded and drill-proven; this column is code-inferred from one commit (4bb11638) of the OSS repo — Everest mount, RBAC, and OIDC/SAML are enterprise deltas noted per cell. Radar overlays show Lean vs lakeFS; the tables carry every column. Cross-references to Lean cells on this page were re-synced to the live scores on 2026-08-27 — three had been quoting pre-rescore values, which is the hazard of hand-writing one page against another page's numbers. Post-publication review lowered Day-2 failure shape 4→3: the two-postures envelope had credited the API/gateway face with lakectl-local's outage behavior.

# Multicluster — many clusters, one bucket

The radar scores on page 1 anchor to the single-cluster case — clients co-located with the share's cluster. This page states each approach's multicluster contract and lists the cells that move when clients span clusters. The direct modes and lakeFS are topology-invariant by construction; the hub column is where multicluster costs land.

**Hub:** coherence survives trivially (one authority) — the contract is network identity. Remote clusters SNAT to one address (1486/1486 measured; nfsClientCIDRs structurally cannot work), per-node NFS client names must be unique across clusters (RFC 8881 case 5 read a colliding name as a reboot and took the incumbent's locks — six 1.37.0 defects, one cause), and remote mounts need a keepalive or idle-suspend kills them. Prefix uniqueness stops at the cluster boundary — equal prefixes contend on the epoch cell, nested ones never meet: allocate prefixes upstream of Kubernetes.

**FUSE / Lean:** native — the bucket is the rendezvous and the arbitration state (epoch, claim, lease, manifest CAS, lean's gateway refusal) is store-side, so cross-cluster behaves exactly like cross-pod: no client identity on any wire, no keepalive, nothing to wake. The residual is the same allocation gap — per-cluster webhooks cannot see each other's subtree grants.

**lakeFS:** the best client story — HTTP + per-request SigV4 means the NFS identity class simply does not exist; N clusters are N sets of HTTP clients. The pivot moves to the database: every replica must share ONE KV (cross-region, a KV round-trip sits inside every commit CAS), and two independent installs on one namespace are fenced only at CREATE time (ensureStorageNamespace's dummy object, controller.go:2426) — a birth check, not a live lease; past it, each install's uncommitted GC treats the other's staged objects as garbage. In one line: the hub makes multicluster a *network-identity* problem, the direct modes an *allocation* problem, lakeFS a *database-topology* problem — share one KV or don't.

**Forge:** HTTP plus a projected token, so the NFS identity class does not exist here either — but the token is proven by THIS cluster's apiserver (`TokenReview`), and a pod in another cluster carries nothing the door can verify: cross-cluster agents fall back to the human bearer until the Knox chain lands. The bucket is a rendezvous for READERS only — a dumb-protocol clone works with the server down — never for a second server: one lease, one prefix, one syncer, and the fence turns a foreign cluster's server into a straggler that exits. Every clone leaves the server's NIC across the cluster boundary, so the storm lever (bundle URIs, served from S3) is the cross-cluster lever too. In one line: forge makes multicluster an *identity-provider* problem.

## What moves — score deltas (single → multicluster)

| Chart · axis | Column | single → multi | Why |
|---|---|---|---|
| **Performance · Stream read / write** | hub sys · krb5p | sys 3.5/3 → 3/2.5<br>krb5p 2/1.5 → 1.5/1 | cross-cluster RTT on every RPC; one NIC now shared by N clusters' clients; often an inter-AZ/region billing path too. |
| **Performance · Small files, Hot loops** | hub sys · krb5p | sys 1.5/2 → 1/1.5<br>krb5p 1/1.5 → 0.5/1 | the metadata path is already round-trip-bound (create 12.5×, delete 222×); every RTT gets longer. |
| **Performance · Small files** | lakeFS | 2.5 → 2 | only when clusters are remote from the lakeFS service; and if replicas span regions, the KV round-trip sits inside every commit CAS. |
| **Day-2 · Failure shape** | hub (both) | 2 → 1.5 | a hub node death now D-state-hangs pods in every mounting cluster — the blast radius multiplies by topology. |
| **Day-2 · Consumer footprint** | hub sys | 4 → 3 | the cross-cluster operating contract lands on consumers: unique per-node client names, a keepalive, a routable advertiseAddress, peering/SGs. (krb5p stays 1 — already the floor.) |
| **Day-2 · Idle lifecycle & wake** | hub (both) | 2.5 → 2 | idle-suspend kills a live remote mount (suspendWithSessions defaults to suspending anyway), and nothing in a remote cluster can write the wake annotation. |
| **Security · Auth** | Forge | {score:Security/Auth/Forge} → 2 | TokenReview proves only this cluster's ServiceAccount tokens; a remote cluster's pods hold no credential the door accepts, so cross-cluster access is the static human bearer until Knox. |
| **Performance · Cold start, Scale-out** | Forge | {score:Performance/Cold start/Forge}/{score:Performance/Scale-out/Forge} → 3.5/2.5 | every clone crosses the cluster boundary from one pod's NIC, often an inter-AZ/region billing path; bundle URIs (client opt-in) move those bytes to S3. |

**Unchanged by design:** every Consistency cell (the hub's coherence is identical for remote clients; the direct modes' contract is already per-subtree snapshots wherever pods run); every FUSE and Lean cell (cross-cluster is cross-pod — the bucket is the rendezvous); every Forge Consistency cell (the server arbitrates wherever the client is); krb5p's auth and wire cells (per-user identity survives any network — this is its selling point). And note the **sec=sys security cells are already scored at the multicluster boundary**: their evidence came from the cross-cluster drills (the 1486/1486 SNAT measurement, "nfsClientCIDRs cannot express a client in another cluster"), so they take no further delta here.

Sources: the N-clusters-one-hub drill campaign and flint-lite-architecture p5 (the cross-cluster operating contract), the fleets guide performance tables (single-cluster, same-AZ anchor), and lakeFS controller.go:2426 (the create-time namespace check). Deltas are estimates from the measured single-cluster numbers plus the documented cross-cluster mechanics — not re-measured; treat them as the direction and rough size of the shift.